보안 검토 보고서 — 보석 맞추기 (jewel-game)

항목	내용
검토 일자	2026-11-07
검토 대상	React + Supabase 버전 (`c156941`), 배포본 https://jewel-game-three.vercel.app , 레거시 `jewel.html`
검토 기준	KISA「AI 보안 위협 대응 매뉴얼」(2026.7) — 제2장 위협 분류, 제3장 4절 교육 시나리오, 제4장 대응 방안
검토 범위	① 애플리케이션(코드·의존성·DB 정책·배포 설정) ② **AI 코딩 에이전트로 개발·배포한 과정**
검토 방법	코드 정적 검토, `npm audit`, git 이력 비밀값 검색, 배포 응답 헤더 확인, Supabase 공개 API 응답 확인, 개발 세션 작업 이력 검토

1. 요약

이 게임 자체는 LLM을 쓰지 않으므로 매뉴얼의 모델·데이터 위협(D01~M08, S01·S02)은 대부분 **해당 없음**이다. 대신 매뉴얼이 다루는 위협이 두 지점에서 그대로 나타난다.

1. **서비스 측면** — 점수를 클라이언트가 그대로 보내는 구조라, 매뉴얼 교육 시나리오 1「학생 성적 유출 및 조작」과 같은 **"검증 없는 API를 통한 기록 조작"** 이 가능하다. 의존성에는 알려진 고위험 취약점이 있다.
2. **개발 과정 측면** — AI 에이전트가 사용자의 로그인 세션으로 GitHub·Vercel·Supabase·Kakao 콘솔을 직접 조작했다. 매뉴얼의 [A01] 부적절한 도구 설계, [A02] 에이전트 하이재킹, [H02] 자율성으로 인한 통제 상실, 대응 방안 1.4「실행 권한 정보 분리 관리」가 적용되는 영역이며, 실제로 **카카오 Client Secret이 에이전트 컨텍스트에 노출**되었다.

위험도	건수	항목
높음	3	F-01 점수 위·변조, F-02 Client Secret 에이전트 노출, F-03 의존성 취약점
중간	3	F-04 에이전트 과도 권한, F-05 개인정보 최소 수집, F-06 요청 빈도 제한 없음
낮음	3	F-07 보안 헤더, F-08 레거시 페이지, F-09 Site URL 설정
정보·확인 필요	2	F-10 공개 키 git 이력, F-11 RLS 적용 여부

최우선 조치 (이번 주)

1. 카카오 **Client Secret 재발급** 후 Supabase에 새 값 입력 (F-02)
2. `react-router-dom` 6.30.6 이상, `@supabase/supabase-js` 2.119.0 이상으로 업데이트 (F-03)
3. 점수 저장을 **서버 측 검증 함수(RPC)** 로 바꾸고 직접 INSERT 권한 회수 (F-01, F-06)
4. 카카오 동의항목에서 이메일을 **선택 동의**로 낮추고, 개인정보 처리 안내 추가 (F-05)

위험도 기준 — **높음**: 지금 악용 가능하거나 비밀값이 이미 노출됨 · **중간**: 조건이 갖춰지면 피해 발생 · **낮음**: 방어 계층 보강 권고 · **정보**: 위험 낮으나 원칙과 불일치

2. 매뉴얼 위협 분류 적용 여부

코드	위협	적용	근거
D01·D02	불균형·부정확 데이터	해당 없음	학습·RAG 데이터 없음
D03	개인정보 비식별화 미흡	**유사 적용**	카카오 닉네임·이메일·프로필 수집, 랭킹에 닉네임 공개 → F-05
M01~M06	학습 데이터·임베딩·프롬프트·모델 유출, 환각, 탈옥	해당 없음	LLM 미사용
M07	부적절한 출력 처리	양호	닉네임 등은 React가 이스케이프하여 출력. 레거시 `innerHTML` 1건(숫자만) → F-08
M08	모델 DoS (대응: 요청 트래픽 제어)	**유사 적용**	점수 저장 API 호출 빈도 제한 없음 → F-06
A01	부적절한 도구 설계	**적용**	점수 API 입력 검증 미흡(F-01), 개발 에이전트 과도 권한(F-04)
A02	에이전트 하이재킹	**적용(개발 과정)**	에이전트가 외부 웹 콘솔을 읽고 동시에 쓰기 작업 수행 → F-04
A03	에이전트 DoS	해당 없음	서비스에 에이전트 없음
A04	에이전트 메모리 오염	낮음	개발 에이전트의 파일 기반 메모리 존재, 오염 징후 없음
S01·S02	데이터·모델 포이즈닝	해당 없음	모델 없음
S03	취약한 버전의 엔진·**라이브러리** 사용	**적용**	`npm audit` 고위험 취약점 → F-03
S04	취약한 확장요소 사용 (대응: 출처·무결성 검증)	**유사 적용**	레거시 페이지 CDN 스크립트 무결성 검증 없음 → F-08
H01	고도화된 사이버 공격 지원	해당 없음	—
H02	자율성으로 인한 통제 상실	**적용(개발 과정)**	짧은 요청을 넓게 해석해 설정 변경 수행 사례 → F-04

3. 세부 발견 사항

F-01 높음 점수를 서버에서 검증하지 않아 랭킹 위·변조 가능

- **매뉴얼 근거**: 제3장 4절 교육 시나리오 1「AI 학사 정보 시스템을 통한 학생 성적 유출 및 조작」의 취약 지점 *"도구 및 API 호출 시 사용자 인증 절차, 스키마 확인 등의 검증 미흡"*, [A01] 부적절한 도구 설계(입력값 검증·실행 조건 제한 미흡)
- **현황**
  - `src/services/scores.js`의 `saveScore()`가 브라우저에서 계산한 `score`를 그대로 `scores` 테이블에 INSERT한다.
  - DB 제약은 `0 ≤ score ≤ 1,000,000`뿐이고, RLS 정책 `scores_insert_own`은 **본인 user_id인지만** 확인한다.

  - 따라서 로그인한 사용자는 개발자 도구나 공개 REST API(`/rest/v1/scores`)로 게임을 하지 않고도 임의 점수(예: 999,999)를 저장할 수 있다.
- **영향**: 랭킹 신뢰도 상실. 교육 현장에서 순위를 보상·평가에 쓰면 매뉴얼이 지적한 *"평가 신뢰성 저하"* 와 같은 문제로 이어진다.
- **권고**
  1. 테이블 직접 INSERT 권한을 회수하고, 검증 로직이 있는 `security definer` 함수로만 저장한다.
  2. 함수에서 **점수 상한**(30회 이동으로 가능한 현실적 최댓값), **최소 플레이 시간**, **저장 간격**을 검사한다.
  3. 근본 대책: 게임 시작 시 서버가 시드·세션 ID를 발급하고, 저장 시 이동 기록을 함께 받아 서버(Edge Function)에서 재계산한다.
  4. 비정상 점수는 저장하지 않고 감사 로그로 남긴다 (대응 방안 1.5 실시간 모니터링).

```
-- 예시: 직접 INSERT 차단 + 검증 함수 (상한값은 실측 후 조정)
drop policy if exists "scores_insert_own" on public.scores;

create or replace function public.submit_score(p_nickname text, p_score int)
returns void language plpgsql security definer set search_path = public as $$
begin
  if auth.uid() is null then raise exception 'not authenticated'; end if;
  if p_score < 0 or p_score > 20000 then raise exception 'invalid score'; end if;
  if exists (select 1 from scores where user_id = auth.uid()
             and created_at > now() - interval '60 seconds') then
    raise exception 'too many requests';
  end if;
  insert into scores (user_id, nickname, score)
  values (auth.uid(), left(coalesce(nullif(trim(p_nickname), ''), '플레이어'), 30), p_score);
end $$;

revoke all on function public.submit_score(text, int) from public, anon;
grant execute on function public.submit_score(text, int) to authenticated;
```

F-02 높음 카카오 Client Secret이 AI 에이전트 컨텍스트에 노출됨

- **매뉴얼 근거**: 제4장 2절 1.4「실행 권한 정보 분리 관리」— *"API 키, 인증 토큰 등은 LLM이 직접 파라미터로 전달하지 않고 … 환경 변수 또는 안전한 비밀 관리 시스템을 활용하여 LLM이 직접 해당 정보를 다루지 않도록 한다."*
- **현황**
  - 개발 중 에이전트가 Kakao Developers의「REST API 키 수정」화면을 페이지 텍스트로 읽었고, 이때 **카카오 로그인용·비즈니스 인증용 Client Secret 코드가 모두 에이전트 대화 기록에 포함**되었다.
  - 에이전트는 비밀값을 입력 칸에 직접 넣지 않고 사용자에게 맡겼다(양호). 하지만 **읽는 것만으로도 노출**이 발생했다.
- **영향**: 대화 기록·로그가 유출되면 제3자가 카카오 로그인 토큰 교환에 해당 시크릿을 쓸 수 있다.
- **권고**
  1. Kakao Developers → 플랫폼 키 → REST API 키 수정 → **클라이언트 시크릿 "코드 재발급"** (카카오 로그인·비즈니스 인증 모두), 새 값을 Supabase Kakao Provider에 다시 입력한다.
  2. 앞으로 비밀값이 표시되는 화면은 에이전트가 읽지 않도록 지시하거나, 해당 단계는 사람이 직접 수행한다.
  3. 에이전트 세션 기록의 보관 위치와 보존 기간을 확인한다.

F-03 높음 의존성에 알려진 취약점 (런타임 5건, 개발용 포함 7건)

- **매뉴얼 근거**: [S03] 취약한 버전의 추론 엔진·**라이브러리** 사용, 제4장 2절 2.3「오픈소스 정기적 보안 업데이트」
- **현황** (`npm audit --omit=dev`, 2026-11-07)

패키지	현재	위험도	내용	조치 버전
`react-router-dom` / `react-router` / `@remix-run/router`	6.28.0	높음	열린 리디렉션, 리디렉션을 통한 XSS 등 (GHSA-2w69-qvjg-hvjx, GHSA-9jcx-v3wj-wh4m, GHSA-wrjc-x8rr-h8h6 외)	6.30.6 이상
`@supabase/supabase-js` / `@supabase/auth-js`	2.49.4	낮음	잘못된 입력에 의한 경로 라우팅 (GHSA-8r88-6cj9-9fh5)	2.119.0 이상
`vite` / `esbuild` (개발용)	5.4.11	중간	개발 서버 응답을 외부 사이트가 읽을 수 있음 (GHSA-67mh-4wv8-2f99)	vite 5.4.21 이상

- **영향**: 현재 코드는 외부 입력으로 경로를 만들지 않아 즉시 악용 가능성은 낮다. 그러나 라우팅 코드가 늘어나면 바로 노출되는 유형이다. vite 취약점은 `npm run dev` 실행 중에만 해당한다.
- **권고**: 위 버전으로 올리고 빌드·동작을 다시 확인한다. GitHub Dependabot 알림을 켜고, 배포 전 `npm audit` 점검을 절차에 넣는다 (매뉴얼: 취약점 모니터링, 패치 적용 주기 관리).
- **양호한 점**: 버전 고정(`package.json` 정확한 버전 + `package-lock.json`)으로 구성요소 목록화와 재현성은 확보되어 있다.

F-04 중간 개발 에이전트가 사용자 로그인 세션의 전체 권한으로 외부 서비스를 조작

- **매뉴얼 근거**: [A01] *"필요한 최소 권한보다 과도한 실행 권한"*, [A02] *"외부 콘텐츠 조회 권한과 상태 변경 실행 권한이 동일 에이전트에 함께 부여된 경우"*, [H02], 대응 방안 1.1 최소 권한, 1.2 Human-in-the-Loop, 1.5 실시간 모니터링
- **현황 — 에이전트가 수행한 외부 변경**

대상	수행 작업	사람 승인
GitHub	공개 저장소 생성, push, Pages 활성화	요청에 포함
Vercel	프로젝트 가져오기·배포 시도 (본인 확인 단계에서 사용자에게 넘김)	요청에 포함
Kakao Developers	카카오 로그인 ON, 리다이렉트 URI 등록, 동의항목 변경	요청에 포함
Supabase	Redirect URL 2건 추가	1건은 **"버셀" 한 단어 요청을 해석해 수행**

```
- 위 작업은 모두 브라우저에 로그인된 **사용자 계정 전체 권한**과 Git 자격 증명으로 실행되었다. 범위를 제한한 토큰은 쓰이지 않았다.
- 에이전트는 같은 세션에서 외부 웹페이지(콘솔 화면)를 읽으면서 설정을 변경했다. 이번에는 악성 지시문이 발견되지 않았지만, [A02]가 말하는 *"읽기·쓰기 권한이 분리되지 않은"* 구조다.
```

- **양호한 점 (HITL 적용 사례)**
  - 비밀번호·API 키·Client Secret 입력, 본인인증, 이메일 인증 코드, 카카오 개인정보 동의는 에이전트가 수행하지 않고 사용자에게 넘겼다.
  - 커밋·푸시는 사용자가 요청했을 때만 했다.
- **권고**
  1. 에이전트용 작업에는 **범위를 제한한 토큰**(GitHub fine-grained token: 해당 저장소만, Vercel 프로젝트 단위 토큰)을 쓰고, 작업 후 회수한다 (1.1).
  2. 저장소 공개, 인증 설정, 리다이렉트 허용 목록 변경 같은 **고위험 설정 변경은 실행 전 확인**을 받는 규칙을 정한다 (1.2 위험 기반 접근법).
  3. 에이전트가 변경한 설정을 작업 후 목록으로 남기고 사람이 검토한다 (1.5).

F-05 중간 개인정보 최소 수집·공개 범위 안내 미흡

- **매뉴얼 근거**: [D03] 개인정보 비식별화 미흡, 대응 방안「개인정보 보호 및 법규 준수」,「개인정보 감사 로깅」
- **현황**
  - 카카오 동의 화면에서 **카카오계정(이메일)이 필수 동의**로 요청된다. 하지만 게임은 이메일을 쓰지 않는다. 이메일은 Supabase가 기본으로 요청하는 항목이라 KOE205 해결을 위해 추가된 것이다.
  - 랭킹은 로그인한 **모든 사용자에게 닉네임**(카카오 프로필 이름, 실명일 수 있음)과 점수·저장 시각을 보여준다.
  - 개인정보 처리 안내(수집 항목, 목적, 보관 기간, 파기, 탈퇴 방법)가 없다.
  - 교육청 특강·학생 대상이라면 **만 14세 미만 이용자의 법정대리인 동의** 문제가 생길 수 있다.
- **권고**
  1. Kakao 동의항목에서 이메일을 **선택 동의**로 바꾼다. Supabase "Allow users without an email"은 이미 켜져 있으므로 동의하지 않아도 로그인된다.
  2. 랭킹 닉네임을 일부 가리거나(예: `홍*동`), 저장할 때 표시 이름을 사용자가 직접 정하게 한다.
  3. 로그인 화면에 개인정보 처리 안내 링크를 두고, 회원 탈퇴 시 `scores`가 함께 지워지는지 확인한다 (`on delete cascade` 설계됨).
  4. 학생 대상 운영 시 만 14세 미만 이용 제한 또는 법정대리인 동의 절차를 둔다.

F-06 중간 점수 저장 요청 빈도 제한 없음

- **매뉴얼 근거**: [M08]·[A03]의 대응 방안「요청 트래픽 제어 설정」, 제4장 2절 1.5「도구·API 비정상적 반복 호출」모니터링
- **현황**: 한 판에 한 번만 저장하는 제한(SAV-3)은 **화면 버튼에만** 있다. API를 직접 호출하면 같은 사용자가 무제한으로 행을 추가할 수 있다.
- **영향**: 랭킹 도배, DB 용량 증가, 무료 요금제 한도 소진
- **권고**: F-01의 검증 함수에 저장 간격 제한을 넣는다. 또는 사용자당 최고 점수 1행만 유지(upsert)하도록 바꾼다. Supabase 대시보드에서 API 사용량 알림을 설정한다.

F-07 낮음 웹 보안 헤더 미설정

- **매뉴얼 근거**: 제4장「안전한 아키텍처 구성」— 구성요소 간 통신 보호, 다층 방어

- **현황**: 배포 응답에 `Strict-Transport-Security`만 있다. `Content-Security-Policy`, `X-Frame-Options`(또는 `frame-ancestors`), `X-Content-Type-Options`, `Referrer-Policy`가 없다.
- **영향**: 다른 사이트가 게임을 iframe으로 감싸는 클릭재킹, 향후 XSS 발생 시 피해 확대
- **권고**: `vercel.json`에 `headers`를 추가한다. CSP의 `connect-src`는 Supabase 주소, `img-src`는 카카오 프로필 이미지 도메인만 허용한다.

F-08 낮음 레거시 `jewel.html` 페이지의 무결성·운영 관리

- **매뉴얼 근거**: [S04], 대응 방안 2.2「외부 구성요소 출처 및 무결성 검증」— *"해시값을 … 대조하고 … 변조 여부를 확인"*
- **현황**
  - jsDelivr CDN의 Supabase 스크립트를 `integrity`(SRI) 속성 없이 불러온다. CDN이 변조되면 로그인 페이지에서 임의 코드가 실행된다.
  - React 버전과 별개로 GitHub Pages에 계속 공개되어 있고, Supabase Redirect URL 허용 목록(`https://pnumin.github.io/jewel-game/**`)도 남아 있다.
  - 게임 종료 화면이 `innerHTML`로 점수를 출력한다. 값이 숫자라 현재 위험은 낮지만, `localStorage` 값을 그대로 쓰는 구조다.
- **권고**: 레거시 페이지를 쓰지 않으면 GitHub Pages를 끄고 Redirect URL에서 제거한다. 유지한다면 `integrity`와 `crossorigin`을 추가하고 `innerHTML`을 `textContent`로 바꾼다.

F-09 낮음 Supabase Site URL이 `http://localhost:3000`

- **현황**: Redirect URL이 허용 목록과 맞지 않으면 Supabase는 Site URL로 돌려보낸다. 지금 값은 개발용 주소다.
- **권고**: Site URL을 `https://jewel-game-three.vercel.app`으로 바꾼다.

F-10 정보 공개용 키가 git 이력에 포함

- **현황**: `843f96c` 커밋의 `jewel.html`에 Supabase **publishable 키**와 프로젝트 주소가 들어 있다. React 버전은 환경변수로 분리되어 있다.
- **평가**: publishable 키는 브라우저에 공개되는 용도라 위험은 낮다. 다만 PRD의 "소스 코드에 Supabase 주소·키가 없다"(인수 기준 8)와 맞지 않는다. `service_role`·`sb_secret` 키는 이력 전체에서 발견되지 않았다.
- **권고**: 이력은 그대로 두되, 레거시 페이지 정리(F-08) 시 함께 제거한다.

F-11 확인 필요 RLS 정책 실제 적용 여부

- **현황**: 비로그인 상태의 `GET /rest/v1/scores` 응답이 `[]`이다. RLS가 동작하는 경우와 일치하지만, 테이블이 비어 있어도 같은 결과가 나온다.
- **권고**: Supabase → Table Editor → `scores`에서 **RLS enabled**와 정책 2개(`scores_select_authenticated`, `scores_insert_own`)가 있는지 확인한다. F-01 조치 후에는 INSERT 정책이 없어야 정상이다.

---

4. 잘 된 점

항목	매뉴얼 대응 방안
Supabase 주소·키를 `VITE_` 환경변수로 분리, `.env.local`·개인 메모 파일을 `.gitignore`로 제외	1.4 실행 권한 정보 분리 관리
`service_role`·`sb_secret` 같은 비밀 키를 프론트엔드에 쓰지 않음 (이력 전체 검색 결과 없음)	1.4
`scores` 테이블 RLS 설계: 조회는 로그인 사용자, 저장은 본인만, 수정·삭제 불가	1.1 최소 권한·역할 기반 접근 제어
사용자 입력(닉네임)을 React 기본 이스케이프로 출력, `dangerouslySetInnerHTML` 미사용	[M07] 출력 후처리
의존성 정확한 버전 고정 + lockfile	2.3 구성 관리 및 기록
HTTPS·HSTS 적용 (Vercel 기본)	안전한 아키텍처 — 통신 암호화
비밀값 입력·본인인증·개인정보 동의를 사람이 직접 수행	1.2 Human-in-the-Loop

5. 조치 계획

순위	ID	조치	담당	권장 기한
1	F-02	카카오 Client Secret 재발급 → Supabase 재입력	운영자	즉시
2	F-03	`react-router-dom`, `@supabase/supabase-js`, `vite` 업데이트 후 재배포	개발	1주
3	F-01, F-06	`submit_score` 검증 함수 적용, 직접 INSERT 정책 제거, 앱 코드 `rpc()` 호출로 변경	개발	1주
4	F-05	이메일 선택 동의로 변경, 개인정보 안내, 닉네임 가림 처리	운영자·개발	2주
5	F-04	에이전트 작업용 제한 토큰 사용, 고위험 설정 변경 승인 규칙	운영자	2주
6	F-07, F-09	`vercel.json` 보안 헤더, Site URL 수정	개발	2주
7	F-08, F-10	레거시 페이지 정리 또는 SRI 적용	개발	1개월
8	F-11	RLS 적용 확인	운영자	즉시
—	전체	분기별 `npm audit`·설정 재점검, 조치 후 재검증	개발	정기

6. 검토의 한계

- 실제 카카오 계정으로 로그인한 상태의 점수 저장·랭킹·RLS 동작은 직접 검증하지 못했다. F-01은 코드와 SQL 정책 기준의 판단이다.
- 침투 테스트·부하 테스트는 수행하지 않았다.
- Supabase·Vercel·Kakao 콘솔의 설정은 이번 세션에서 확인한 시점 기준이며, 이후 변경분은 반영되지 않았다.
- 원격 `origin/main`에 로컬보다 앞선 커밋(`843f96c`)이 있어 레거시 `jewel.html`은 그 버전 기준으로 검토했다.
- 매뉴얼은 LLM 시스템을 대상으로 하므로, LLM을 쓰지 않는 이 앱에는 위협 분류를 **유사 적용**했다 (§2 표).